IoT Security Challenges

A Case Study on Vulnerabilities, Real-World Attacks and Defensive Strategies

Mini Project - Internet of Things (Task 4)

Abstract. The Internet of Things (IoT) connects billions of sensors, cameras, vehicles and appliances to the internet, but many of these devices are built with cost and speed in mind rather than security. This case study examines why IoT systems are difficult to secure, analyses three well-documented incidents (the Mirai botnet, the Jeep Cherokee remote hack and the Verkada camera breach), compares their root causes, and reviews the technical controls, standards and regulations that organisations can adopt to reduce risk.

Contents

1. Introduction 2. Background: The IoT Attack Surface 3. Major Security Challenges 4. Case Studies 5. Comparative Analysis 6. Mitigation Strategies 7. Standards and Regulation 8. Future Outlook 9. Conclusion References

1. Introduction

The Internet of Things refers to physical objects embedded with sensors, software and network connectivity so that they can collect and exchange data with little or no human involvement. Examples range from smart thermostats and wearable trackers to industrial controllers, medical infusion pumps, connected cars and city-wide traffic systems. Industry analysts estimate that there are well over fifteen billion connected IoT devices worldwide, and the number continues to grow every year.

This growth has a security cost. Every connected device is a potential entry point into a home, a company or a public utility. Unlike a laptop or a smartphone, an IoT device is often cheap, runs for years without maintenance, has very little processing power, and may never receive a security update. Attackers have learned to exploit these weaknesses at scale, turning ordinary cameras and routers into weapons for large denial-of-service attacks, spying tools or stepping stones into corporate networks.

Objective. This case study aims to (i) explain why IoT security is fundamentally harder than conventional IT security, (ii) study real incidents to understand how attacks actually happen, and (iii) summarise practical measures for manufacturers, organisations and users.

2. Background: The IoT Attack Surface

A typical IoT deployment has four layers, and each layer introduces its own risks. Understanding these layers helps explain why a single weak component can compromise the entire system.

Layer	Typical components	Common weaknesses
Device / perception	Sensors, actuators, cameras, microcontrollers	Default passwords, unsigned firmware, exposed debug ports, physical tampering
Network / communication	Wi-Fi, Bluetooth, Zigbee, LoRaWAN, cellular, MQTT, CoAP	Unencrypted traffic, weak pairing, replay and man-in-the-middle attacks
Cloud / platform	Data storage, device management, APIs, dashboards	Weak authentication, over-privileged access, insecure APIs, misconfiguration
Application / user	Mobile apps, web portals, voice assistants	Poor access control, phishing, privacy leaks, insecure companion apps

Table 1: The four-layer IoT architecture and its typical weaknesses.

Because these layers are tightly connected, security must be considered end to end. A hardened cloud platform offers little protection if the devices attached to it can be hijacked using a factory-default password.

3. Major Security Challenges

3.1 Weak or default authentication

Many devices ship with well-known default usernames and passwords such as admin/admin, and users rarely change them. Some products even contain hard-coded credentials that cannot be changed at all. Automated scanners can find and log in to thousands of such devices within hours.

3.2 Limited resources

Low-cost microcontrollers have little memory and battery capacity, which makes strong cryptography, secure boot and intrusion detection difficult to implement. Manufacturers frequently drop these features to save cost or power.

3.3 Insecure updates and long lifecycles

Devices such as smart meters, industrial sensors and medical equipment may stay in service for ten to twenty years. Many have no over-the-air update mechanism, or the vendor stops issuing patches after a short period, leaving known vulnerabilities open indefinitely. Where updates exist, unsigned firmware can itself become an attack path.

3.4 Insecure communication and data protection

Sensitive data such as video feeds, location history and health readings is sometimes transmitted or stored without encryption. Weak protocols allow eavesdropping, tampering and replay attacks, creating serious privacy risks as well as security ones.

3.5 Scale, heterogeneity and lack of visibility

IoT networks combine devices from many vendors using many protocols, so there is no single security standard to rely on. Organisations often do not even know how many connected devices they own (the problem of "shadow IoT"), which makes monitoring and patching difficult.

3.6 Physical access and supply-chain risk

Devices are often deployed in public or unattended locations where attackers can touch them, extract firmware or connect to debug interfaces. In addition, compromised components or third-party software libraries can introduce vulnerabilities before the product even reaches the customer.

4. Case Studies

4.1 Case 1: The Mirai Botnet (2016)

What happened. In 2016 the Mirai malware infected large numbers of internet-connected cameras, digital video recorders and home routers. It worked by scanning the internet for devices that accepted telnet connections and then trying a short list of factory-default usernames and passwords. Infected devices joined a botnet controlled by the attackers. In September 2016 the botnet was used to launch a record-setting attack on the security journalist Brian Krebs' website, and on 21 October 2016 it was used against the DNS provider Dyn, which disrupted access to many popular websites including Twitter, Netflix and Reddit for several hours.

Why it worked. The vulnerable devices had default or hard-coded passwords, exposed remote-access services, and no easy way for owners to patch them. Owners usually did not notice the infection because the devices kept working normally. Soon after the attacks, the Mirai source code was published online, and numerous variants have appeared since.

Impact and lessons. Mirai showed that individually low-value devices become highly dangerous when combined at scale, and that the victim of an IoT weakness may be a third party rather than the device owner. It directly motivated later regulation banning universal default passwords.

4.2 Case 2: The Jeep Cherokee Remote Hack (2015)

What happened. In 2015 security researchers Charlie Miller and Chris Valasek demonstrated that they could take control of a Jeep Cherokee over the internet while a journalist drove it on a highway. They gained access through the vehicle's infotainment system, which was reachable over the cellular network, and then sent commands to internal systems, affecting functions such as the air conditioning, radio, wipers, transmission and brakes. The manufacturer subsequently recalled about 1.4 million vehicles to install a software fix.

Why it worked. An internet-facing service was exposed with insufficient protection, and the entertainment system was not properly isolated from safety-critical vehicle networks. The case

illustrates how a connectivity feature added for convenience can create physical safety risks.

Impact and lessons. The incident pushed the automotive industry toward network segmentation, secure over-the-air updates and vulnerability disclosure programmes, and it showed that IoT security failures can threaten human life, not only data.

4.3 Case 3: The Verkada Camera Breach (2021)

What happened. In March 2021 a group of hackers gained access to the cloud-based management system of Verkada, a company that provides security cameras to offices, hospitals, schools, factories and prisons. Reports indicated that the attackers obtained administrator-level credentials that had been exposed on the internet, giving them visibility into live and archived video from roughly 150,000 cameras.

Why it worked. A privileged credential was exposed and the internal tooling gave broad access across customers. Excessive privileges and weak internal access controls meant that one compromised account had enormous reach.

Impact and lessons. The breach showed that the cloud back end is as critical as the device itself, that surveillance data is highly sensitive, and that principles such as least privilege, multi-factor authentication and strict credential management are essential for IoT service providers.

5. Comparative Analysis

Although the three incidents involve different technologies, they share a small number of recurring root causes. Table 2 compares them.

Aspect	Mirai (2016)	Jeep Cherokee (2015)	Verkada (2021)
Target layer	Device	Device and network	Cloud / platform
Main weakness	Default passwords, open telnet	Exposed service, poor network isolation	Exposed admin credential, excess privilege
Primary harm	Large-scale denial of service	Physical safety risk	Privacy and surveillance exposure
Victim	Third-party websites and DNS	Drivers and the manufacturer	Customers and people on camera
Key fix	Unique credentials, patching, ban on defaults	Segmentation, secure OTA updates	Least privilege, MFA, credential hygiene

Table 2: Comparison of the three case studies.

Three common themes emerge. First, **basic security hygiene** (unique passwords, closed ports, protected credentials) would have prevented or limited every incident. Second, **security was treated as an afterthought** rather than being designed in from the start. Third, **the consequences extended beyond the device owner**, affecting other organisations, the public, or personal safety. This last point is why IoT security is often described as a market failure: the party that decides how secure a device is (the manufacturer) is not the party that bears the cost of its insecurity.

6. Mitigation Strategies

Effective IoT security combines measures at several levels. The following controls are widely recommended.

6.1 For manufacturers

- **Secure by design:** perform threat modelling early and remove unnecessary services and debug interfaces before shipping.
- **Unique credentials:** never ship with a shared default password; require users to set one during setup or provide a unique per-device password.
- **Secure boot and signed firmware:** allow only authenticated code to run, using a hardware root of trust where possible.
- **Update and support policy:** provide automatic, signed over-the-air updates and publish how long support will last.
- **Vulnerability disclosure:** offer a public channel through which researchers can report flaws responsibly.

6.2 For organisations and network operators

- **Asset inventory and monitoring:** discover every connected device and monitor traffic for abnormal behaviour.
- **Network segmentation:** place IoT devices in separate VLANs so that a compromised camera cannot reach core business systems.
- **Zero-trust approach:** authenticate every device and user, grant the minimum access needed, and use multi-factor authentication for management consoles.
- **Encryption:** use TLS or DTLS for data in transit and encrypt sensitive data at rest.
- **Patch and retire:** apply updates promptly and replace devices that are no longer supported.

6.3 For consumers

- Change default passwords immediately, enable automatic updates, disable features that are not needed, keep devices on a guest network, and prefer products from vendors who publish clear security support periods.

7. Standards and Regulation

After incidents such as Mirai, governments and standards bodies began to move from voluntary guidance toward enforceable requirements. Table 3 lists some of the most influential frameworks.

Framework	Origin	Key idea
OWASP IoT Top 10	OWASP community	Ranks the most common IoT vulnerabilities, such as weak passwords and insecure update mechanisms
NIST IR 8259	United States (NIST)	Baseline cybersecurity activities that manufacturers should perform for IoT devices
ETSI EN 303 645	Europe (ETSI)	Consumer IoT baseline: no universal default passwords, vulnerability reporting, software updates, secure communication
UK PSTI Act 2022	United Kingdom	Legally requires connected-product makers to meet security rules, including banning default passwords (in force from 2024)
EU Cyber Resilience Act	European Union	Mandatory cybersecurity requirements for products with digital elements throughout their lifecycle
US Cyber Trust Mark	United States (FCC)	Voluntary label that helps consumers identify products meeting security criteria

Table 3: Selected IoT security standards and regulations.

The direction of travel is clear: security is becoming a legal and commercial requirement for market access rather than an optional feature. Nevertheless, standards differ between regions, and enforcement against low-cost imported devices remains a challenge.

8. Future Outlook

Several trends will shape IoT security over the coming years.

- **AI-assisted defence and attack:** machine learning can detect anomalous device behaviour, but attackers can also use automation and AI to find vulnerable devices faster.
- **Edge computing:** processing data closer to the device reduces exposure and latency, but moves security responsibilities to many more distributed nodes.
- **5G and massive connectivity:** a much larger number of connected devices will enlarge the attack surface and raise the stakes of network-level attacks.
- **Lightweight and post-quantum cryptography:** constrained devices will need efficient algorithms, and long-lived devices must plan for the eventual arrival of quantum-capable adversaries.
- **Device identity and Software Bills of Materials (SBOMs):** hardware-backed identities and transparent lists of software components will make it easier to trace and fix vulnerabilities across supply chains.

9. Conclusion

IoT devices bring enormous benefits in convenience, efficiency and automation, but they also introduce a large and often poorly defended attack surface. The Mirai, Jeep Cherokee and Verkada incidents demonstrate that serious harm, ranging from internet outages to physical danger and mass surveillance, frequently results from basic and avoidable weaknesses such as default passwords, exposed services and over-privileged accounts.

Reducing these risks requires shared responsibility. Manufacturers must build security in from the start and support products throughout their life; organisations must segment, monitor and manage their connected assets; regulators must set clear minimum requirements; and users must adopt safe habits. As IoT expands into smart cities, healthcare and critical infrastructure, treating security as a core design requirement rather than an add-on will determine whether the technology earns lasting public trust.

References

[1] Antonakakis, M., et al. (2017). Understanding the Mirai Botnet. *Proceedings of the 26th USENIX Security Symposium*.

[2] Miller, C., and Valasek, C. (2015). Remote Exploitation of an Unaltered Passenger Vehicle. Technical white paper.

[3] Greenberg, A. (2015). Hackers Remotely Kill a Jeep on the Highway. *WIRED*.

[4] Bloomberg News (2021). Hackers Expose the Fragility of Video Surveillance (Verkada breach reporting).

[5] OWASP Foundation. OWASP Internet of Things Project - IoT Top 10.

[6] National Institute of Standards and Technology (2020). NISTIR 8259: Foundational Cybersecurity Activities for IoT Device Manufacturers.

[7] ETSI (2020). ETSI EN 303 645: Cyber Security for Consumer Internet of Things: Baseline Requirements.

[8] UK Government (2022). Product Security and Telecommunications Infrastructure Act 2022.

[9] European Union (2024). Regulation on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act).